

Bonus 2 Isolare un Host Compromesso Usando la 5Tupla

Obiettivi

A seguito di una compromissione della rete, gli utenti hanno segnalato l'inaccessibilità del file riservato confidential.txt. L'indagine di incident response è stata condotta correlando gli eventi tramite la 5-tupla (**IP sorgente, Porta sorgente, IP destinazione, Porta destinazione, Protocollo di trasporto L4**) attraverso la suite di Security Onion, articolandosi in tre fasi sequenziali:

Fase	Strumento	Obiettivo Analitico
Parte 1	Sguil (NIDS / Snort / OSSEC)	Identificazione e triage degli alert in tempo reale, estrazione della 5-tupla e analisi preliminare dei comandi.
Parte 2	Wireshark (Pivoting da Sguil)	Ricomposizione del flusso TCP completo (TCP Stream eq 0) e analisi del dump dei file sensibili esfiltrati.
Parte 3	Kibana (Zeek / Bro Logs)	Pivoting su indirizzi IP, tracciamento dell'esfiltrazione via FTP/FTP-DATA e recupero del payload del file compromesso.

Nota: Se questa fosse una rete di produzione, si raccomanda che gli utenti **analyst** e **root** cambino le loro password e si conformino all'attuale politica di sicurezza.

Parte 1: Esaminare gli Alert in Sguil

RealTime Events Escalated Events										
ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1	seconion-import-1	5.1	2020-06-11 03:41:20	209.165.200.235	6200	209.165.201.17	45415	6	GPL ATTACK_RESPONSE id check returned root
RT	351	seconion-ossec	1.1	2020-06-19 18:09:28	0.0.0.0		0.0.0.0		0	[OSSEC] File added to the system.
RT	23	seconion-ossec	1.2	2020-06-19 18:09:29	0.0.0.0		0.0.0.0		0	[OSSEC] Integrity checksum changed.

☒ Show Packet Data	☒ Show Rule
alert ip any any -> any any (msg:"GPL ATTACK_RESPONSE id check returned root"; content:"uid=0 28 root 29"; fast_pattern:only; classtype:bad-unknown; sid:2100498; rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23;) /nsm/server_data/securityonion/rules/seconion-import-1/downloaded.rules: Line 700	

RealTime Events		Escalated Events						
ST	CNT	Sensor	Alert ID	Date/Time	Δ	Src IP	SPort	Dst IP
RT	1	seconion-import-1	5.1	2020-06-11 03:41:20		209.165.200.235	6200	209.165.201.17
RT	351	seconion-ossec	Event History	09:28		0.0.0.0		0.0.0.0
RT	23	seconion-ossec	Transcript	09:29		0.0.0.0		0.0.0.0
RT	7	seconion-ossec	Transcript (force new)	10:04		0.0.0.0		0.0.0.0
RT	7	seconion-ossec	Wireshark	10:04		0.0.0.0		0.0.0.0
			Wireshark (force new)					

seconion-import-1_1

File

Sensor Name: seconion-import-1
Timestamp: 2020-06-11 03:41:20
Connection ID: .seconion-import-1_1
Src IP: 209.165.201.17
Dst IP: 209.165.200.235
Src Port: 45415
Dst Port: 6200
OS Fingerprint: 209.165.201.17:45415 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7::??] (up: 6267 hrs)
OS Fingerprint: -> 209.165.200.235:6200 (link: ethernet/modem)

SRC: id
SRC:
DST: uid=0(root) gid=0(root)
DST:
SRC: nohup >/dev/null 2>&1
SRC:
SRC: echo uKgoT8McFDrCw7u2
SRC:
DST: uKgoT8McFDrCw7u2
DST:
SRC: whoami
SRC:
DST: root
DST:
SRC: hostname
SRC:
DST: metasploitable
DST:
SRC: ifconfig
SRC:

Search

Abort

Close

Debug Messages

Your request has been sent to the server.
Please be patient as this can take some time.
Using archived data:
/nsm/server_data/securityonion/archive/2020-06-11/seconion-import-1/209.165.201.17:45415_209.165.200.235:6200-6.raw

seconion-import-1_1

File

DST: msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
DST: bind:x:105:113:/var/cache/bind:/bin/false
DST: postfix:x:106:115:/var/spool/postfix:/bin/false
DST: ftp:x:107:65534:/home/ftp:/bin/false
DST: postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
DST: mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false
DST: tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
DST: distccd:x:111:65534:/bin/false
DST: user:x:1001:1001:just a user,111,,/home/user:/bin/bash
DST: service:x:1002:1002,,/home/service:/bin/bash
DST: te
DST: inetd:x:112:120:/nonexistent:/bin/false
DST: proftpd:x:113:65534:/var/run/proftpd:/bin/false
DST: statd:x:114:65534:/var/lib/nfs:/bin/false
DST: analyst:x:1003:1003:Security Analyst,,/home/analyst:/bin/bash
DST:
SRC: cat /etc/passwd | grep root
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST:
SRC: echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
SRC:
SRC: grep root /etc/passwd
SRC:
DST: root:x:0:0:root:/root:/bin/bash
DST: myroot:x:0:0:root:/root:/bin/bash
DST:
SRC: exit
SRC:

Search

Abort

Close

Debug Messages

Your request has been sent to the server.
Please be patient as this can take some time.
Using archived data:
/nsm/server_data/securityonion/archive/2020-06-11/seconion-import-1/209.165.201.17:45415_209.165.200.235:6200-6.raw

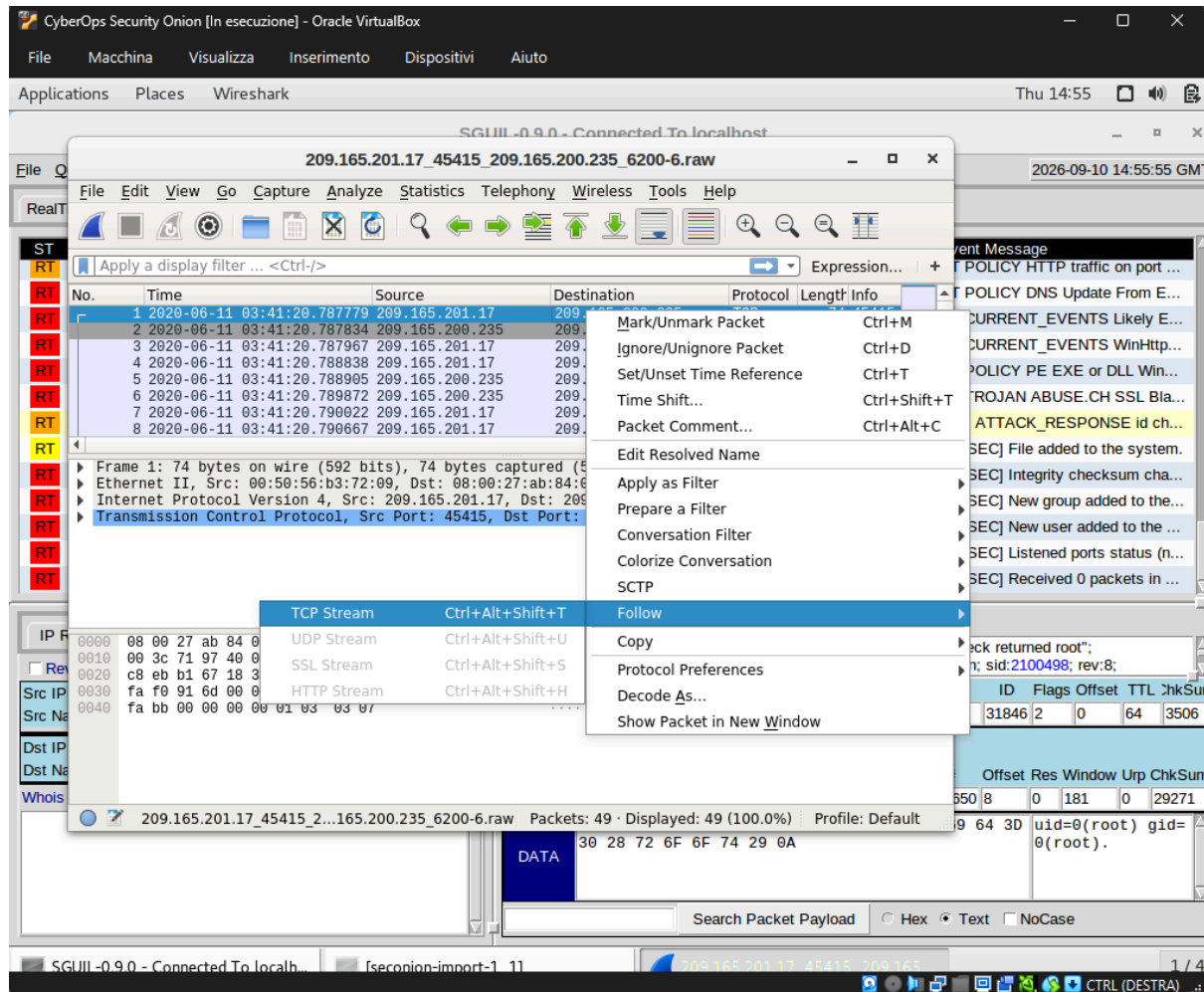
Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

Dalle trascrizioni di Sguil emerge una sessione shell interattiva non autenticata sulla porta 6200, articolata in tre fasi principali:

- 1. **Ricognizione e verifica privilegi:** L'attaccante invia **id** e **whoami**; il target risponde con **uid=0(root) gid=0(root)**, attestando l'esecuzione con privilegi root massimi. Vengono eseguiti test di reattività (**nohup >/dev/null 2>&1** ed **echo uKgoT8McFDrCw7u2**), identificato l'**hostname** (**metasploitable**) e ispezionate le interfacce di rete (**ifconfig**).
- 2. **Ispezione degli account di sistema:** L'attaccante visualizza **/etc/passwd** per mappare gli account registrati (**msfadmin**, **analyst**, **postgres**, **mysql**, ecc.) e filtra la voce di root (**cat /etc/passwd | grep root**).
- 3. **Persistenza (Backdoor Account):** L'attaccante inserisce un account permanente con privilegi di root eseguendo **echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd**, ne verifica l'inserimento con **grep root /etc/passwd** ed esce dalla sessione.

Parte 2: Passare a Wireshark

Per visualizzare tutti i pacchetti assemblati in una conversazione TCP, fai clic con il pulsante destro su un pacchetto qualsiasi e seleziona Follow > TCP Stream.





Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

L'attaccante esegue il comando whoami sul bersaglio.

Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

Scorri il flusso TCP. Che tipo di dati ha letto l'attore della minaccia?

Domanda Investigativa	Evidenza Ricontrata
Cosa indicano i colori del testo (Rosso / Blu)?	• Rosso: Traffico inviato dal client attaccante verso il server (comandi digitati). • Blu: Risposte generate dal server verso il client (output di console del bersaglio).
Cosa rivela l'output di whoami sul ruolo dell'attaccante?	Restituisce ' root ', confermando che l' attaccante opera con il livello massimo di privilegi (UID 0) , con accesso incondizionato all'intero sistema.
Che tipo di dati critici ha letto l'attore della minaccia?	1. Topologia di rete: configurazione di eth0 (IP 209.165.200.235, MAC 08:00:27:ab:84:07). 2. Hash delle password (/etc/shadow): dump integrale degli hash cifrati di tutti gli account locali (inclusi root e analyst). 3. Database account (/etc/passwd): lista completa degli utenti locali, shell e percorsi home.

```
sys:$1$fUX6BP0t$MiyC3Up0zQJqz4s5wFD9l0:14742:0:99999:7:::
sync*:14684:0:99999:7:::
games*:14684:0:99999:7:::
man*:14684:0:99999:7:::
lp*:14684:0:99999:7:::
mail*:14684:0:99999:7:::
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$K3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
analyst:$1$uvEqE7eT$X6gcZc318aD6mHX0FZqXE.:17338:0:99999:7:::
echo "myroot::14747:0:99999:7:::" >> /etc/shadow
grep root /etc/shadow
root:$1$avpfBJ1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
myroot::14747:0:99999:7:::
cat /etc/passwd
```

Packet 24. 14 client pkts, 11 server pkts, 20 turns. Click to select.

Entire conversation (4,388 bytes)

Find:

```
news*:14684:0:99999:7:::
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$K3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
analyst:$1$uvEqE7eT$X6gcZc318aD6mHX0FZqXE.:17338:0:99999:7:::
echo "myroot::14747:0:99999:7:::" >> /etc/shadow
grep root /etc/shadow
root:$1$avpfBJ1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
myroot::14747:0:99999:7:::
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
```

Packet 24. 14 client pkts, 11 server pkts, 20 turns. Click to select.

Entire conversation (4,388 bytes)

Find:

```
uucp*:14684:0:99999:7:::
proxy*:14684:0:99999:7:::
www-data*:14684:0:99999:7:::
backup*:14684:0:99999:7:::
list*:14684:0:99999:7:::
irc*:14684:0:99999:7:::
gnats*:14684:0:99999:7:::
nobody*:14684:0:99999:7:::
libuuid:!:14684:0:99999:7:::
dhcp*:14684:0:99999:7:::
syslog*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind*:14685:0:99999:7:::
postfix*:14685:0:99999:7:::
ftp*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfCYe/:14685:0:99999:7:::
mysql:!:14685:0:99999:7:::
tomcat55*:14691:0:99999:7:::
distccd*:14698:0:99999:7:::
user:$1$HESu9xrH$K.o3G93DGoXIiQKkPmUgZ0:14699:0:99999:7:::
service:$1$K3ue7JZ$7GxELDupr50hp6cjZ3Bu//:14715:0:99999:7:::
telnetd*:14715:0:99999:7:::
proftpd:!:14727:0:99999:7:::
statd*:15474:0:99999:7:::
analyst:$1$uvEqE7eT$X6gcZc318aD6mHX0FZqXE.:17338:0:99999:7:::
echo "myroot::14747:0:99999:7:::" >> /etc/shadow
grep root /etc/shadow
root:$1$avpfBJ1$X0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
myroot::14747:0:99999:7:::
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
```

Packet 33. 14 client pkts, 11 server pkts, 20 turns. Click to select.

```
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/:/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,:/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002,,:/home/service:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false
analyst:x:1003:1003:Security Analyst,,:/home/analyst:/bin/bash
cat /etc/passwd | grep root
root:x:0:0:root:/root:/bin/bash
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
myroot:x:0:0:root:/root:/bin/bash
exit
```

Esci dalla finestra del flusso TCP. Chiudi Wireshark quando hai finito di esaminare le informazioni fornite.

Parte 3: Passare a Kibana

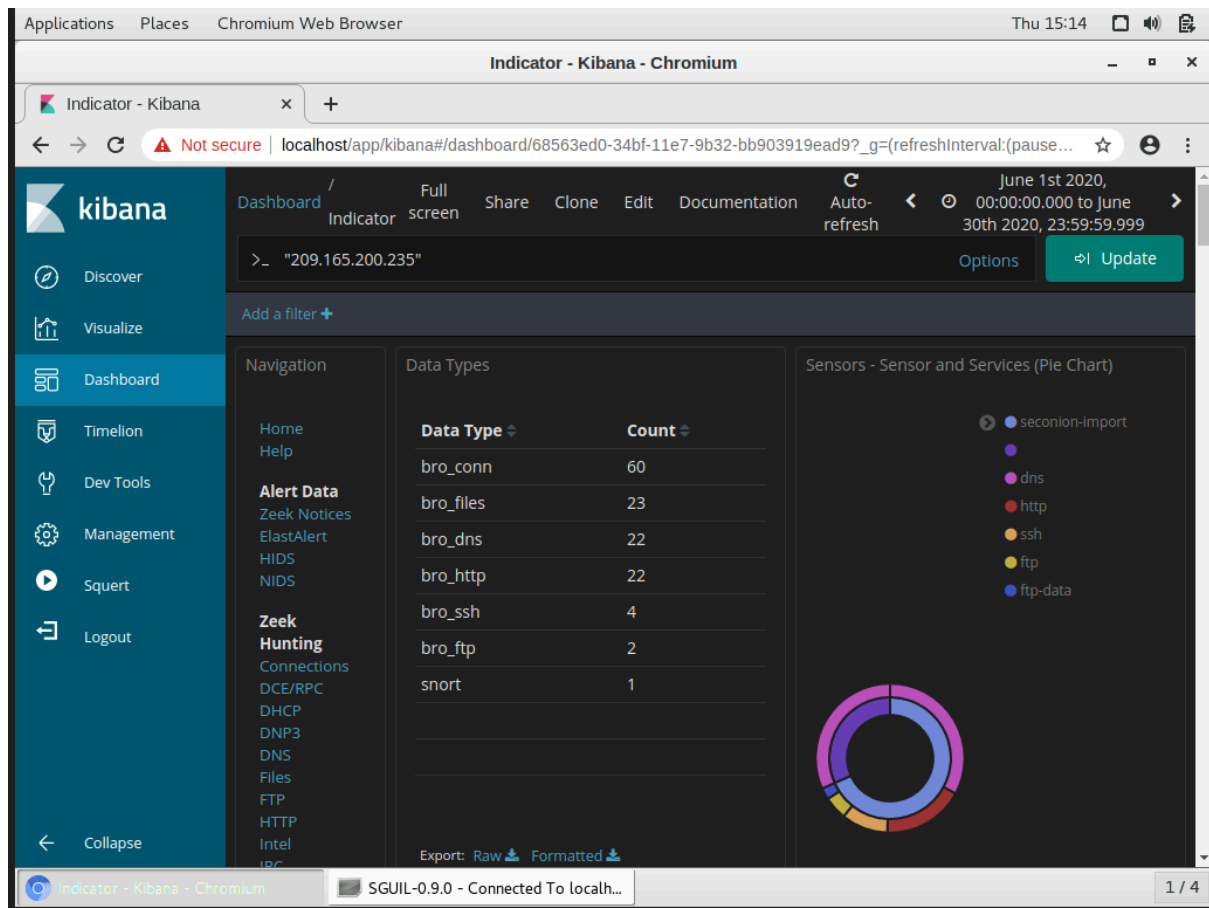
Torna a Sguil. Fai clic con il pulsante destro sull'indirizzo IP di origine o di destinazione per l'ID dell'alert 5.1 e seleziona Kibana IP Lookup > SrcIP. Inserisci il nome utente analyst e la password cyberops se richiesto da Kibana.

The screenshot shows the Sguil-0.9.0 interface running in a VirtualBox environment. The main window displays a list of events under the 'RealTime Events' tab. The table has columns: ST, CNT, Sensor, Alert ID, Date/Time, Src IP, SPort, Dst IP, DPort, Pr, and Event Message. A context menu is open over the 'Src IP' column of the first event (Alert ID 5.1, Src IP 172.16.4.205). The menu options include: Quick Query, Advanced Query, Dshield IP Lookup, Copy IP Address, Alexa IP Lookup, Bing IP Lookup, CentralOps IP Lookup, DomainTools IP Lookup, Google IP Lookup, Kibana IP Lookup (selected), MDL IP Lookup, SafeBrowsing IP Lookup, VirusTotal IP Lookup, and ZeusTracker IP Lookup. The 'Kibana IP Lookup' option is highlighted, and a sub-menu is visible showing 'SrcIP' and 'DstIP' options. Below the table, there are tabs for 'IP Resolution', 'Agent Status', 'Snort Statistics', and 'System Msg'. The 'System Msg' tab is active, showing a 'Whois Query' section with radio buttons for 'None', 'Src IP', and 'Dst IP'. The 'Src IP' option is selected. The bottom of the window shows a taskbar with various icons and a system tray area.

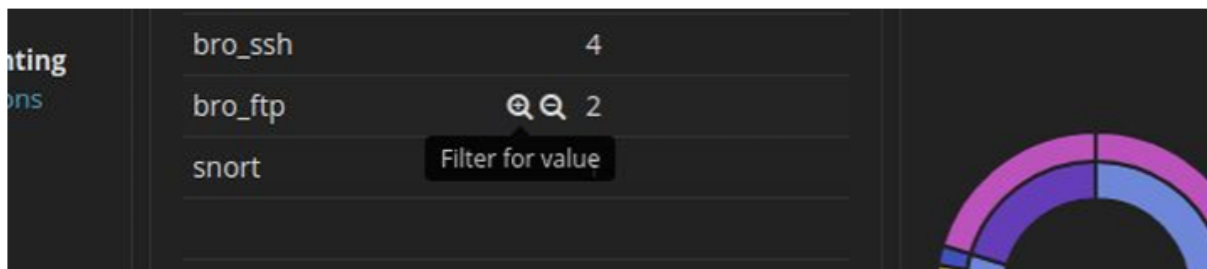
Nota: Se ricevi il messaggio “La tua connessione non è privata”, fai clic su AVANZATE > Procedi su localhost (non sicuro) per continuare.

Se l'intervallo di tempo è impostato sulle ultime 24 ore, cambialo a Giugno 2020 in modo che l'11 giugno sia incluso nell'intervallo. Usa la scheda Absolute per cambiare l'intervallo di tempo.

Nei risultati visualizzati, c'è un elenco di diversi tipi di dati. Ti è stato detto che il file confidential.txt non è più accessibile. Nel grafico a torta “Sensors - Sensors and Services”, sono presenti ftp e ftp-data. Determineremo se FTP è stato usato per rubare il file.



Filtriamo per `bro_ftp`. Passa il mouse sullo spazio vuoto accanto al conteggio dei tipi di dati `bro_ftp`. Seleziona `+` per filtrare solo il traffico relativo a FTP come mostrato in figura.



Scorri verso il basso fino a All Logs. Ci sono due voci elencate.

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

All Logs 1-2 of 2

Time ▾	source_ip	source_port	destination_ip	destination_port	uid
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	C5GkeA4t8oXZdWTPR6
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	C5GkeA4t8oXZdWTPR6

1-2 of 2

Dall'analisi delle voci filtrate per `bro_ftp` nella sezione All Logs di Kibana per questo laboratorio:

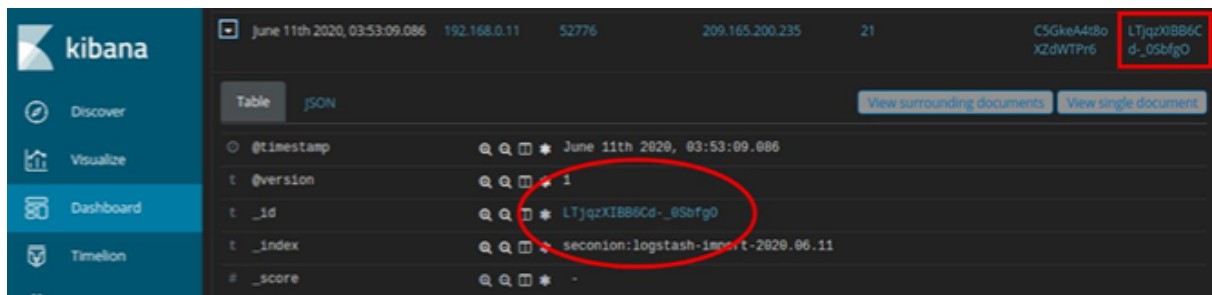
- **Sorgente (Source):**
 - IP di origine: 192.168.0.11
 - Porta di origine: 52776 (porta effimera del client FTP)
- **Destinazione (Destination):**
 - IP di destinazione: 209.165.200.235 (il server bersaglio compromesso)
 - Porta di destinazione: 21 (porta di controllo standard FTP)

Questo indica che un host interno (192.168.0.11) ha aperto una sessione FTP verso il server vittima (209.165.200.235) sulla porta 21 per trasferire il file `confidential.txt`.

f. Espandi ed esamina entrambe le voci di log. In una di queste voci, il campo `ftp_argument` ha una voce di <ftp://209.165.200.235/./confidential.txt>. Esamina anche il messaggio nella voce di log per saperne di più su questo evento.

t	ftp_argument	ftp://209.165.200.235/./confidential.txt
t	ftp_command	STOR
t	fuid	FX1iV63eSMAEiN16S2
t	host	d68c9360b6ae
t	ips	209.165.200.235, 192.168.0.11
t	message	{ "ts": "2020-06-11T03:53:09.086840Z", "uid": "C5GkeA4t8oXZdWTPR6", "id": "92.168.0.11", "id.orig_p": 52776, "id.resp_h": "209.165.200.235", "id.resp_p": 21, "user": "analyst", "password": "<hidden>", "command": "STOR", "arg": "ftp://209.165.200.235/./confidential.txt", "mime_type": "text/plain", "reply_code": 200, "reply_msg": "Transfer complete.", "fuid": "FX1iV63eSMAEiN16S2" }
t	mime_type	text/plain

All'interno della stessa voce di log, scorri di nuovo verso l'alto fino al campo `alert_id` e fai clic sul link.



Esamina la trascrizione per le transazioni tra l'attaccante e il bersaglio. Se lo desideri, puoi scaricare il pcap ed esaminare il traffico usando Wireshark.

close

[192.168.0.11:52776_209.165.200.235:21-6-1079711344.pcap](#)

```
Log entry:
{"ts":"2020-06-11T03:53:09.086840Z","uid":"C5GkeA4t8oXZdWTPR6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete.", "fuid":"FX1IV63eSMAEiN16S2"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 52776
Dst Port: 21
OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7:..?:?] (up: 3131 hrs)
OS Fingerprint -> 209.165.200.235:21 (link: ethernet/modem)
DST: 220 (vsFTPD 2.3.4)
DST:
SRC: USER analyst
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
SRC: SYST
SRC:
DST: 215 UNIX Type: L8
DST:
SRC: TYPE I
SRC:
```

```
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
SRC: SYST
SRC:
DST: 215 UNIX Type: L8
DST:
SRC: TYPE I
SRC:
DST: 200 Switching to Binary mode.
DST:
SRC: PORT 192,168,0,11,194,153
SRC:
DST: 200 PORT command successful. Consider using PASV.
DST:
SRC: STOR confidential.txt
SRC:
DST: 150 Ok to send data.
DST:
DST: 226 Transfer complete.
DST:
SRC: QUIT
SRC:
DST: 221 Goodbye.
DST:

DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:52776_209.165.200.235:21-6.raw
QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
CAPME: Processed transcript in 0.63 seconds: 0.32 0.20 0.00 0.10 0.00

192.168.0.11:52776_209.165.200.235:21-6-1079711344.pcap
```

Quali sono le credenziali utente per accedere al sito FTP?

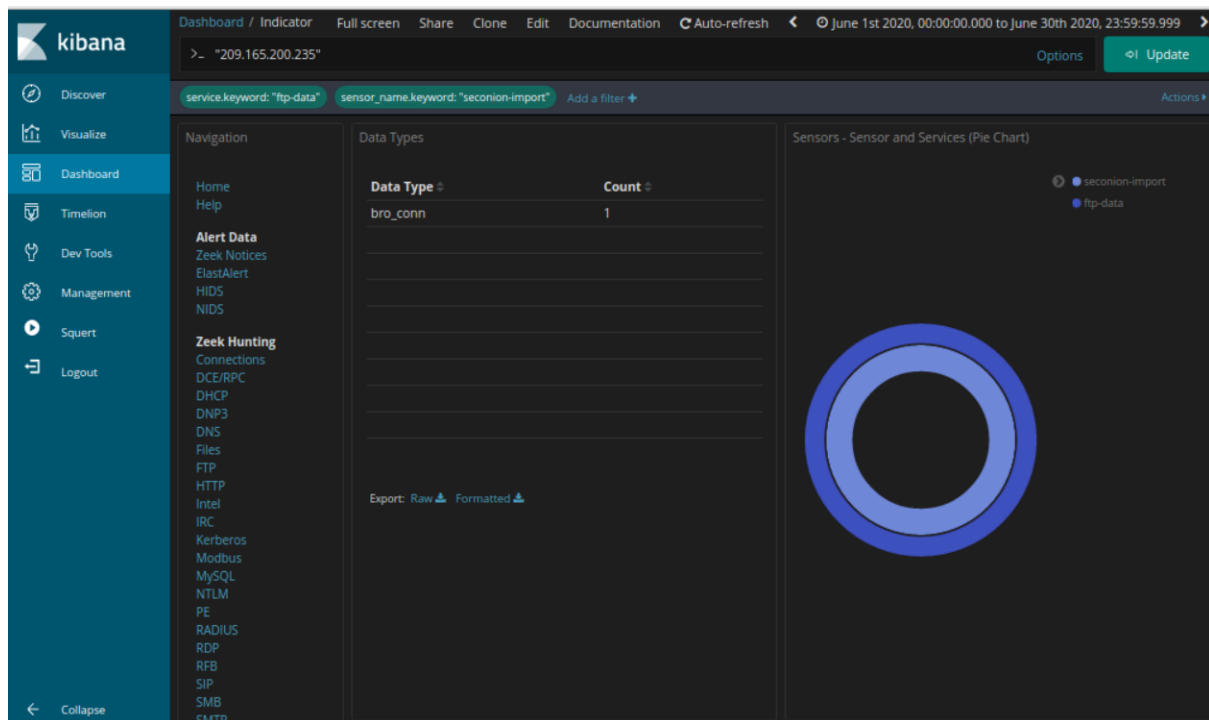
Le credenziali utilizzate dal client (SRC) per autenticarsi sul server FTP (DST) sono:

- **Nome utente (Username):** `analyst` (inviato con il comando `SRC: USER analyst`)
- **Password:** `cyberops` (inviata in chiaro con il comando `SRC: PASS cyberops`)

Il server conferma l'avvenuto accesso subito dopo con il messaggio `DST: 230 Login successful..`

i. Ora che hai verificato che l'attaccante ha usato FTP per copiare il contenuto del file `confidential.txt` e poi cancellarlo dal bersaglio.

Qual è il contenuto del file? Ricorda che uno dei servizi elencati nel grafico a torta è `ftp_data`?



All Logs

Field	Value
@version	1
_id	p2jqzx1885cd-0ss_gj
_index	seconion:logstash-import-2020.06.11
_score	-
_type	doc
connection_state	SF
connection_state_description	Normal SYN/FIN completion

192.168.0.11:49817 209.165.200.235:20-6-458360280.pcap

Log entry:

```
{
  "ts": "2020-06-11T03:53:09.087738Z",
  "uid": "C2Jv8MWV6Xg4lbb51",
  "id.orig_h": "209.165.200.235",
  "id.orig_p": 20,
  "id.resp_h": "192.168.0.11",
  "id.resp_p": 49817,
  "proto": "tcp",
  "service": "ftp-data",
  "duration": 0.001316070556640625,
  "orig_bytes": 0,
  "resp_bytes": 102,
  "conn_state": "SF",
  "missed_bytes": 0,
  "history": "ShAdlFa",
  "orig_pkts": 4,
  "resp_pkts": 4,
  "resp_ip_bytes": 318,
  "sensorname": "seconion-import"
}
```

Sensor Name: seconion-import
 Timestamp: 2020-06-11 03:53:09
 Connection ID: CLI
 Src IP: 192.168.0.11
 Dst IP: 209.165.200.235
 Src Port: 49817
 Dst Port: 20
 OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
 OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)

SRC: CONFIDENTIAL DOCUMENT
 SRC: DO NOT SHARE
 SRC: This document contains information about the last security breach.
 SRC:

DEBUG: Using archived data: /nsm/server_data/seconionon/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
 QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
 CAPME: Processed transcript in 0.87 seconds: 0.28 0.50 0.00 0.09 0.00

192.168.0.11:49817 209.165.200.235:20-6-458360280.pcap

j. Naviga in cima al dashboard. Seleziona Files sotto l'intestazione Zeek Hunting nel pannello di sinistra, come mostrato in figura. Questo ti permetterà di esaminare i tipi di file che sono stati registrati.



Quali sono i diversi tipi di file? Guarda la sezione MIME Type dello schermo. Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencate?

Tipi di file (sezione MIME Type) I tipi di file elencati sull'asse orizzontale del grafico sono:

- text/plain
- image/jpeg
- image/png
- text/html
- image/gif
- image/x-icon

Sorgenti dei file (sezione Files - Source) Le sorgenti dei file elencate con i rispettivi conteggi sono:

- HTTP (Conteggio: 22)
- FTP_DATA (Conteggio: 1)

k. Filtra per FTP_DATA passando il mouse sullo spazio vuoto accanto al conteggio per FTP_DATA e fai clic su +.

Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP? Quando si è verificato questo trasferimento?

0

text/plain

MIME Type

Files - Source

Source	Count
FTP_DATA	1

Files - Files By Size (Bytes)

Bytes Seen	Count
102B	1

1 - 1 of 1

<

>

Time	file_ip	destination_ip	source	uid	fuid	_id
▶ June 11th 2020, 03:53:09.088	192.168.0.11	209.165.200.235	FTP_DATA	C2Jv8MWV6Xg4lbb51	FX1IV63eSMAEIN1652	KDjqzXIBB6Cd_0SVfy

1 - 1 of 1

<

>

- Tipo MIME: `text/plain`
- Indirizzo IP di origine (**file_ip**): `192.168.0.11`
- Indirizzo IP di destinazione (**destination_ip**): `209.165.200.235`
- Data e ora dell'evento (**Time**): `June 11th 2020, 03:53:09.088` (11 giugno 2020 alle 03:53:09 UTC)

m. Nei log dei file, espandi la voce associata ai dati FTP. Fai clic sul link associato all'alert_id.

Qual è il contenuto testuale del file trasferito tramite FTP?

close

[192.168.0.11:49817_209.165.200.235:20-6-458360280.pcap](#)

Log entry:

```
{
  "ts": "2020-06-11T03:53:09.087738Z",
  "uid": "C2Jv8MWV6Xg4lbb51",
  "id.orig_h": "209.165.200.235",
  "id.orig_p": 20,
  "id.resp_h": "192.168.0.11",
  "id.resp_p": 49817,
  "proto": "tcp",
  "service": "ftp-data",
  "duration": 0.001316070556640625,
  "orig_bytes": 0,
  "resp_bytes": 102,
  "conn_state": "SF",
  "missed_bytes": 0,
  "history": "ShAdIFa",
  "orig_pkts": 4,
  "orig_ip_bytes": 216,
  "resp_pkts": 4,
  "resp_ip_bytes": 318,
  "sensorname": "seconion-import"
}
```

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
OS Fingerprint -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)

SRC: CONFIDENTIAL DOCUMENT
SRC: DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:

DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
CAPME: Processed transcript in 0.87 seconds: 0.28 0.50 0.00 0.09 0.00

[192.168.0.11:49817_209.165.200.235:20-6-458360280.pcap](#)

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

Per contenere l'attacco ed eliminare la persistenza dell'attore della minaccia, sono necessarie azioni immediate sull'host compromesso e sul perimetro di rete:

Azioni immediate di contenimento e bonifica (Host `209.165.200.235`)

- **Rimuovere l'account backdoor:** eliminare la voce non autorizzata `myroot` sia da `/etc/passwd` che da `/etc/shadow`.
- **Disabilitare/aggiornare il servizio vulnerabile:** fermare il daemon in ascolto sulla porta `6200` (la backdoor associata alla vulnerabilità di `vsftpd` v2.3.4) e applicare la patch o disinstallare il servizio.
- **Reimpostare tutte le credenziali:** poiché l'attaccante ha letto interamente `/etc/shadow`, forzare il cambio password immediato per tutti gli account locali esposti (inclusi `root`, `analyst`, `msfadmin` e gli account dei database).
- **Rivedere o dismettere il servizio FTP in chiaro:** disabilitare l'accesso FTP standard (porta 21) non cifrato, sostituendolo con protocolli sicuri come SFTP o FTPS con autenticazione a chiavi o MFA.

Azioni di isolamento e sicurezza di rete

- **Isolamento dell'host vittima:** disconnettere temporaneamente `209.165.200.235` dalla rete locale per verificare che non siano stati installati altri rootkit o script di persistenza.
- **Isolamento e verifica dell'host interno (`192.168.0.11`):** analizzare la macchina interna che ha effettuato l'upload FTP per capire se si tratta di una seconda macchina compromessa o di una stazione controllata dall'attore della minaccia.
- **Regole firewall perimetrali:** bloccare il traffico in ingresso verso porte non autorizzate o insolite (come la porta TCP `6200`) e bloccare a monte l'indirizzo IP malevolo esterno `209.165.201.17`.